

DeepSeek Harness: итог доработки

Что исправлено, как исправлено и как теперь всё работает — на Windows-сервере и на Mac · 7 октября 2026

Коротко. При проверке первой версии нашлось шесть слабых мест — все исправлены. Окончательная версия (коммит 7507d5c) проверена целиком: на Windows-сервере в изолированных виртуальных машинах и на рабочем Mac. **Всё работает и на Windows, и на Mac**, все проверки пройдены. По ходу нашлись и исправлены ещё несколько проблем — в том числе возможность для агента попросить выйти из песочницы и выход команд агента в интернет на Mac. Код опубликован: github.com/yantripe/deepseek-harness-local.

1. Как была устроена проверка

Windows проверялась на трёх виртуальных машинах (настройки основного компьютера не менялись), затем Harness поставили на рабочий Mac.

Машина	Роль	Интернет
Чистая сборочная	Свежая Windows 11 без личных файлов. Здесь скачаны Node.js (хэш сверен с официальным), зависимости, выполнены сборка, аудит уязвимостей и тесты	Да, весь трафик записан
Тестовая («сервер»)	Сюда перенесена готовая сборка; настроено всё по новой инструкции; выполнены все испытания	Нет
«Компьютер сотрудника»	Сборочная машина после сборки, отключённая от интернета: с неё открывали интерфейс в браузере	Нет
Рабочий Mac	MacBook Pro 2017, macOS Ventura: установка, сборка, работа агента с локальной моделью	Только для установки

Перенос — только копированием файлов VirtualBox, с проверкой контрольных сумм. Сборка на «сервере» совпала со сборкой из чистой машины байт в байт: 24 155 файлов, одинаковый хэш манифеста. После исправлений, найденных на Mac, вся программа проверок Windows выполнена ещё раз — на окончательной версии. Прежние отметки PASS первого раунда как доказательство не использовались — всё проверено заново.

2. Слабые места и что сделано

2.1. Картинки из ответов модели

Проблема. Если модель вставит в ответ картинку с внешнего сайта, браузер того, кто открыл интерфейс, сам скачает её с этого сайта. Файрвол сервера тут не поможет: запрос идёт с компьютера сотрудника.

Что сделали. Две защиты, независимые друг от друга:

- интерфейс показывает картинку, только если она лежит на самом Harness; картинка с чужого адреса превращается в подпись-текст;
- сервер в каждом ответе отправляет браузеру правило безопасности (Content-Security-Policy): загружать картинки, шрифты, фреймы и открывать соединения можно только с самого Harness. Браузер сам откажется обращаться к чужим адресам, даже если где-то в интерфейсе найдётся ещё одно место со ссылкой наружу.

Как проверили. Сотрудник подключился к серверу через SSH-туннель и открыл ответ модели, в котором три картинки с внешних адресов. На экране вместо картинок — подписи, браузер не сделал ни одного запроса наружу. Контроль: тот же браузер на обычной странице с внешней картинкой

запрос сделал — значит, регистратор работает.

2.2. Права на служебные файлы

Проблема. Журнал со ссылкой для входа, история и настройки были доступны агенту и другим пользователям Windows.

Что сделали.

- папка C:\dsh закрыта для всех обычных пользователей; служебная учётка только читает программу и пишет в свои папки;
- на папки с настройками, историей и журналами поставлена метка Windows «средний уровень, запрет чтения снизу». Команды агента выполняются с **низким** уровнем, поэтому не могут прочитать эти папки, а сам Harness работает как обычно;
- встроенные инструменты чтения файлов отказываются открывать секреты, учётные данные, историю и журналы (правка в коде).

Как проверили. Обычный пользователь — «доступ запрещён» ко всему. Команда агента в песочнице — «доступ запрещён» к журналу с токеном, учётным данным и настройкам, при этом рабочая папка читается. Агент через инструмент чтения — «protected Harness path».

2.3. Цепочка «токен → вход → терминал»

Проблема. Агент мог прочитать ссылку для входа, войти в управление Harness и открыть терминал без ограничений.

Что сделали. Разорвали каждое звено:

- токен агенту недоступен (п. 2.2);
- встроенный терминал оператора выключен — он работал вне песочницы;
- при каждом перезапуске службы меняется ключ подписи входа: все ранее выданные входы перестают действовать;
- **агент больше не может попросить выйти из песочницы.** Раньше после отказа он мог запросить «полный доступ», и один клик оператора запускал команду без ограничений. Теперь повышение возможно только с «чтения» до «записи в рабочую папку» — тоже внутри песочницы.

Как проверили. Агент читает журнал — отказ. Агента прямо попросили взять «полный доступ» — инструмент такого варианта не предлагает, чтение снова отказано. Агент сам попытался «починить права» встроенным навыком — навык не смог ничего изменить. Обращение агента к API Harness — ответ 401. Вход по ссылке работает; после перезапуска службы старые cookie и ссылка получают 401.

2.4. Уязвимые зависимости

Что сделали. Подняли версии уязвимых пакетов до исправленных (в рамках тех же мажорных версий), пересобрали и прогнали тесты. Во время проверки на Mac вышел новый бюллетень по библиотеке MCP — её тоже обновили.

Результат. В зависимостях, которые работают на сервере, было **21 уязвимость уровня high — стало 0**. Остались только пакеты инструментов разработки (менеджер пакетов, сайт документации, упаковка десктопа, тестовая обвязка), которые на сервере не запускаются; для каждого в отчёте есть объяснение. Тесты затронутых пакетов: 1431 прошёл.

2.5. Инструкция и файрвол

Проблема. В первой версии инструкции были правила «блокировать всё исходящее». В файрволе Windows блокирующее правило сильнее любого разрешающего — они перекрывали бы нужные исключения. Сборку предлагалось делать на сервере.

Что сделали. Осталась политика «исходящие запрещены» и точечные разрешения. Сборка — в отдельной чистой машине, на сервер переносятся готовые архивы, установка идёт без интернета строго по списку версий (lockfile).

Как проверили. Служба и команды агента не выходят в интернет (сайты, IP-адреса, IPv6, DNS — отказ). По журналу Windows за весь раунд Harness и Ollama соединялись только с 127.0.0.1. После перезагрузки всё поднялось само, права, метки и файрвол сохранились. Удалённый вход — официальный OpenSSH 9.5: у сотрудника нет командной строки, разрешён только туннель к интерфейсу, проброс на другие порты отклоняется, напрямую по сети порт интерфейса недоступен.

2.6. Окружение и «тихое ослабление»

Проблема. Лишние переменные окружения могли попасть к агенту; без защитного патча или при другом адресе модели защита могла незаметно ослабнуть.

Что сделали.

- службы запускаются со «стерильным» окружением — только перечисленные переменные;
- команды агента получают переменные только из белого списка;
- защитные настройки встроены в саму сборку: облачные провайдеры, плагины, загрузка страниц, терминал и «полный доступ» выключены, даже если патч сервера удалить;
- модель вызывается только на этом же компьютере; любой другой адрес — ошибка `REMOTE_ENDPOINT_BLOCKED`.

Как проверили. Удалили патч — всё осталось выключенным, запрос к модели остановлен с ошибкой. Указали адрес DeepSeek и чужой IP — запрос заблокирован, ни одной попытки соединения. Попытка включить «полный доступ» через переменную окружения — не сработала.

3. Итог проверок

Проверка	Статус
Сборка на сервере = сборка из чистой машины (24 155 файлов)	PASS
Harness и модель слушают только 127.0.0.1	PASS
Заголовок безопасности (CSP) на всех ответах	PASS
Обычный пользователь Windows не видит файлов Harness	PASS
Команда агента не читает журнал с токеном, учётные данные, настройки, историю	PASS
Инструмент чтения агента отказывает на служебных файлах	PASS
Агент не может выйти из песочницы, даже если его прямо попросить	PASS
Встроенный навык «починки прав» не даёт агенту доступа	PASS
Агент не может войти в API Harness (401)	PASS
Перезапуск службы отзывает старые входы	PASS
Нет выхода в интернет у службы и у команд агента	PASS
Команды агента видят только разрешённые переменные окружения	PASS
Агент нормально работает в рабочей папке	PASS
Агент не выходит в интернет; инструмента загрузки страниц нет	PASS
Без патча защита сохраняется; облако не включается	PASS
Чужой адрес модели блокируется без попыток соединения	PASS
Вход сотрудника через SSH-туннель: без командной строки, только интерфейс	PASS
Браузер сотрудника: ответ модели с внешними картинками — ни одного запроса наружу	PASS
После перезагрузки всё сохраняется	PASS
Мас: установка, сборка, чат, инструменты агента в рабочей папке	PASS
Мас: команды агента без интернета и без доступа к секретам Harness	PASS
Мас: веб-интерфейс только на 127.0.0.1, вход по токenu, CSP	PASS

4. Что нашлось по ходу и как исправлено

- **Mac: команды агента выходили в интернет и читали секреты через bash** — песочница macOS ограничивала только запись. Теперь она запрещает исходящие соединения и чтение защищённых файлов Harness. Проверено: curl — заблокирован, чтение — «Operation not permitted».
- **Mac: инструменты агента не работали с llama.cpp** — адаптер модели ждал поле, которого llama.cpp не присылает. Исправлено; проверено и на Mac (llama.cpp), и на Windows (Ollama).
- **Новая уязвимость в библиотеке MCP** — версия поднята, снова 0 уязвимостей уровня high.
- **Правило безопасности ломало интерфейс** (пустая страница): загрузчику плагинов нужен eval. Разрешили его; запрет внешних загрузок остался в силе.
- **Агент мог попросить выйти из песочницы**. Закрыто в коде: повышение только с «чтения» до «записи в рабочую папку». Проверено: даже прямой просьбой агент «полный доступ» не получает.
- **Инструкция: офлайн-установка rpnm 11 без двух настроек** бесконечно стучится в интернет; `icacls /T` с флагами наследования оставлял файлы без прав; установщик OpenSSH не работал из-за переменной TEMP. Всё исправлено.
- **После перезагрузки** Windows запускала только одну из двух служб — добавлен сторожевой повтор каждые 5 минут; после повторной перезагрузки обе службы и SSH поднялись сами.

Что остаётся учитывать

- правило безопасности разрешает eval — нужно интерфейсу; внешние загрузки при этом закрыты;
- агент читает файлы, доступные служебной учётке и не защищённые метками (общие папки) — не хранить там конфиденциальное;
- встроенные разрешающие правила файрвола для системных служб Windows на реальном сервере стоит ревизовать;
- поставляется веб-версия; десктоп-приложение не собирается;
- облачные модели по API в этой сборке заблокированы намеренно; их подключение — решение ответственного за безопасность: код и файлы уйдут внешнему провайдеру.

5. Как теперь всё работает

Шаг	Что происходит
1. Сборка	В отдельной чистой машине с интернетом: проверенный Node.js, зависимости, сборка, аудит, тесты, манифест хэшей
2. Перенос	Архивы + контрольные суммы на сервер без интернета; установка строго по lockfile; сверка манифеста
3. Защита сервера	Служебная учётка без прав администратора; права и метки на папки; файрвол «исходящие запрещены»; службы с явным окружением
4. Работа	Harness и Ollama общаются только внутри сервера (127.0.0.1). Модель — только локальная
5. Доступ сотрудников	Через SSH-туннель, по ссылке с одноразовым токеном; браузер получает правило «ничего не грузить снаружи»
6. Отзыв доступа	Перезапуск службы — и все прежние входы недействительны
7. Mac	Сервер модели llama.cpp на 127.0.0.1, запуск Harness двойным щелчком по <code>~/dsh/start-harness.command</code> ; команды агента в песочнице macOS без интернета

6. Где что лежит

Папка в C:\rabota\yantripe	Что это
1_Harness_код	Окончательный код (коммит 7507d5c), архив и все изменения после первого раунда
2_Комплект_для_отправки	Готовый комплект для отправки, итоговый отчёт, инструкция для сервера
3_Проверки	Журналы всех проверок, журнал безопасности Windows, записи трафика, скрипты
4_Mac	Набор для установки на Mac
5_Mac_результат	Итог и журналы проверки на Mac